

AI Agents for DevSecOps

Automating Secure Infrastructure, Delivery, and Incident Response with LLM-Powered Orchestration

Presented by Deepanshu Kukreja

DEVSECOPS · AI · PLATFORM ENGINEERING



The Manual Toil Problem

DevSecOps teams own a vast operational surface, yet most organizations still rely on engineers to manually execute repetitive, high-stakes tasks across the entire lifecycle.

Alert Triage

Manually reviewing and prioritizing hundreds of security and operational alerts per shift

Config Validation

Hand-checking IaC, Kubernetes manifests, and pipeline configs for policy compliance

Incident Runbooks

Executing multi-step investigation runbooks under pressure with limited tooling

Vuln Management

Inspecting scan results, triaging severity, and coordinating remediation manually

What AI Agents Bring to the Table

AI agents powered by Large Language Models act as **intelligent orchestration layers**, reasoning across context, invoking tools, and taking structured action across the DevSecOps lifecycle without requiring manual handoffs.



The Orchestration Architecture



Model Context Protocol (MCP)

MCP provides a standardized, secure interface for agents to interact with external systems, enabling consistent tool invocation, scoped permissions, and auditable interactions across every integrated platform.

Structured Tool Access

Agents call tools via declared schemas, not free-form execution

Scoped Permissions

Each agent context carries only the minimum required access

Full Auditability

Every tool call is logged for compliance and forensic review

CHAPTER 1

Infrastructure as Code

Generating, validating, and enforcing secure IaC at scale, before anything reaches production.

AI-Assisted IaC Generation & Validation

Agents can generate compliant Terraform modules, validate resource configurations against policy-as-code frameworks, and detect configuration drift, all before a plan is applied.

1

Generate

Produce Terraform from intent descriptions, enforcing org standards and naming conventions

2

Validate

Run OPA/Sentinel policies, scan with Checkov or tfsec, flag misconfigurations pre-apply

3

Drift Detection

Compare live state against declared config and surface unauthorized changes for review



CHAPTER 2

CI/CD Security & Kubernetes Governance

Embedding security intelligence directly into delivery pipelines and cluster control planes.

Securing Pipelines & Clusters

CI/CD Pipeline Security

AI agents review pull requests for secrets exposure, dependency vulnerabilities, and policy violations. They annotate findings inline, block non-compliant merges, and surface context-aware remediation guidance, reducing review burden without sacrificing rigor.

- Secret scanning with contextual explanation
- SBOM analysis and dependency risk scoring
- Policy gate enforcement on merge events

Kubernetes Governance

Agents continuously audit admission control policies, RBAC configurations, and namespace isolation. They flag workloads violating PodSecurity standards, identify privilege escalation paths, and recommend remediation aligned to CIS Kubernetes Benchmarks.

- Admission webhook policy review
- RBAC least-privilege enforcement
- Runtime anomaly context enrichment

CHAPTER 3

Vulnerability Management & Compliance

From scanner noise to prioritized, explainable remediation at machine speed.



Intelligent Vulnerability Analysis

AI agents ingest findings from security scanners, enrich them with exploit context and asset criticality, and produce prioritized remediation plans, eliminating manual triage bottlenecks.

Contextual Enrichment

Correlate CVEs with EPSS scores, public exploit availability, and affected asset blast radius

Risk-Based Prioritization

Score findings against business criticality, exposure, and existing compensating controls

Compliance Mapping

Map findings to control frameworks (SOC 2, FedRAMP, ISO 27001) and generate evidence artifacts

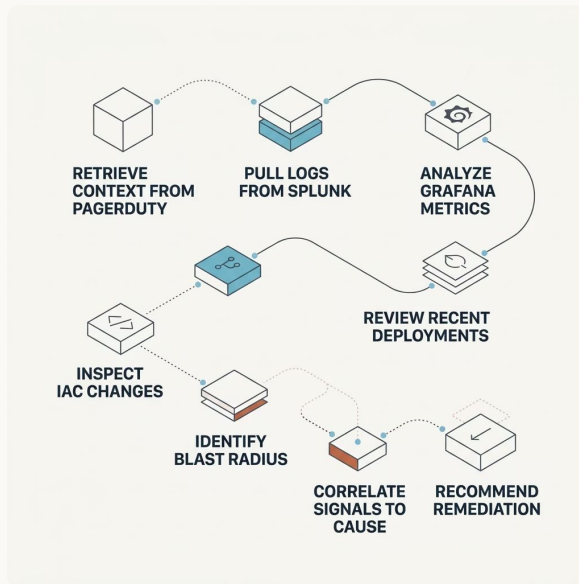
CHAPTER 4

Incident Investigation

A structured, repeatable 16-step workflow that transforms reactive response into systematic analysis.

The 16-Step Investigation Workflow

A reusable agent workflow that guides structured incident analysis, from context retrieval to escalation, ensuring no step is skipped under pressure.



Why a Structured Workflow Matters

Ad-hoc investigation under incident pressure introduces inconsistency, missed signals, and delayed resolution. A structured agent workflow enforces discipline, ensuring telemetry, change history, and blast radius are always assessed before a root cause is declared.

- ❏ High-risk remediation actions always require explicit human approval before execution. The agent surfaces options; it does not act unilaterally.

CHAPTER 5

Guardrails & Human-in-the-Loop

Security, explainability, and compliance are not optional. They are architectural requirements.

Essential Safeguards for AI-Assisted Automation

Autonomous agents without guardrails are a liability. These controls ensure AI automation remains trustworthy, auditable, and compliant in regulated enterprise environments.

Least-Privilege Access

Agents are granted only the minimum tool permissions required for each defined workflow

Policy-as-Code Gates

OPA or Sentinel policies evaluate agent-proposed changes before any action is taken

Approval Gates

High-impact or destructive actions require explicit human approval with full context surfaced

Immutable Audit Trails

Every agent action, tool call, and decision is logged for forensic review and compliance evidence

Human-in-the-Loop

Agents recommend and escalate; humans retain authority over risk-bearing decisions

What Your Team Gains

AI agents don't replace your engineers — they eliminate toil so engineers can focus on what matters most: resilience, architecture, and continuous security improvement.

Reduced Manual Work

Repetitive triage, validation, and runbook execution handled automatically

Faster Secure Delivery

Policy checks and security reviews embedded in the delivery pipeline, not bolted on after

Stronger Incident Response

Structured investigation workflows reduce time-to-root-cause and prevent missed signals

Explainable Automation

Guardrails, audit trails, and human gates keep AI assistance transparent and compliant

 The goal is not full autonomy: it is **trusted, governed, and auditable AI assistance** that makes your DevSecOps practice measurably more secure and resilient.

Thank You